concatenates the user-supplied space name and owner into the SQL `INSERT` statement:

```
database.updateUnique(
"INSERT INTO spaces(space_id, name, owner) " +
"VALUES(" + spaceId + ", '" + spaceName +
"', '" + owner + "');");
```

The `spaceId` is a numeric value that is created by your application from a sequence, so that is relatively safe, but the other two variables come directly from the user. In this case, the input comes from the JSON payload, but it could equally come from query parameters in the URL itself. All types of requests are potentially vulnerable to injection attacks, not just POST methods that include a payload.

In SQL, string values are surrounded by single quotes and you can see that the code takes care to add these around the user input. But what happens if that user input itself contains a single quote? Let’s try it and see:

```
$ curl -i -d "{\"name\": \"test'space\", \"owner\":
\"demo\"}"
[CA]http://localhost:4567/spaces
HTTP/1.1 500 Server Error
Date: Wed, 30 Jan 2019 16:39:04 GMT
Content-Type: text/html;charset=utf-8
Transfer-Encoding: chunked
Server: Jetty(9.4.8.v20171121)
{"error":"internal server error"}
```